

SECURENOVA INC.

Global AI Security & Identity Governance Division

ENTERPRISE AI IDENTITY SECURITY POLICY

Non-Human Identity Lifecycle, Credential Governance & Incident Response Framework

Document Identifier	SEC-POL-AI-2026-01
Document Version	1.0.0 (Enterprise Final Release)
Effective Date	August 24, 2026
Review Frequency	Annual (Next Review: August 2027)
Document Owner	AI Identity Security Lead / Analyst
Approval Authority	CISO & Executive AI Governance Board (APPROVED)

TABLE OF CONTENTS

1. Executive Summary & Purpose
2. Scope & Applicability
3. SecureNova AI Architecture & Trust Boundaries
4. Governance Roles & Responsibilities Matrix
5. SECTION 1 — AI IDENTITY LIFECYCLE MANAGEMENT
5.1 Non-Human Identity (NHI) Provisioning & Approval Matrix
5.2 Mandatory 90-Day Access Review Cycle
5.3 Continuous Telemetry & Runtime Monitoring
5.4 Cryptographic Key Rotation & Token Lifecycles
5.5 Automated Identity Suspension & Quarantine
5.6 Permanent Decommissioning & Audit Trail Retention
6. SECTION 2 — CREDENTIAL GOVERNANCE & SECRETS MANAGEMENT
6.1 Prohibition of Long-Lived Agent Credentials
6.2 Centralized Vault & Key Management Service (KMS) Architecture
6.3 Mandatory Maximum 90-Day API Key Rotation Protocol
6.4 Short-Lived OAuth 2.0 M2M Tokens (TTL <= 300s)
6.5 Principle of Least Privilege & Scope Enforcement
6.6 Emergency Credential Revocation & Break-Glass Workflow
7. SECTION 3 — INCIDENT RESPONSE PLAYBOOK
7.1 Incident Scenario A: Leaked LLM API Key
7.2 Incident Scenario B: Compromised AI Agent Identity / Spoofed Agent
7.3 Incident Scenario C: Prompt Injection Resulting in Data Exfiltration
8. Compliance Mappings (NIST AI RMF 1.0 & OWASP Top 10 for LLM)
9. Policy Enforcement, Exceptions & Disciplinary Actions
10. Annual Review Schedule & References

1. Executive Summary & Purpose

SecureNova Inc. has deployed an advanced AI-powered customer service platform leveraging autonomous LLM agents, Retrieval-Augmented Generation (RAG) vector pipelines, Model Context Protocol (MCP) server tool gateways, and internal REST APIs. The platform acts autonomously and on behalf of authenticated human customers. While these capabilities provide substantial operational efficiency, they introduce novel threat vectors targeting Non-Human Identities (NHIs), including prompt injection, agent impersonation, token exfiltration, and supply chain poisoning.

The purpose of this Enterprise AI Identity Security Policy is to establish mandatory, enforceable controls governing the complete lifecycle, authentication, authorization, credential management, runtime monitoring, and incident response procedures for all human and machine identities interacting with SecureNova AI systems. This policy operationalizes Zero Trust principles across all AI trust boundaries and aligns directly with the NIST AI Risk Management Framework (AI RMF 1.0) and the OWASP Top 10 for LLM Applications (2025).

2. Scope & Applicability

This policy applies enterprise-wide across all AI workloads at SecureNova Inc., encompassing:

- All AI Agent Orchestrators, sub-agents, and background autonomous workers.
- Identity and Access Management (IAM) systems, specifically Auth0 IdP configurations, OAuth 2.0 flows, and SSO.
- Model Context Protocol (MCP) tool execution gateways and internal REST APIs.
- Knowledge ingestion pipelines, embedding models, and Vector Database stores (RAG).
- Model provider credentials, Machine-to-Machine (M2M) secrets, and cryptographic signing keys (Ed25519).

3. SecureNova AI Architecture & Trust Boundaries

Trust Boundary	Interface / Transition	Security Control & Protocol
TB-1: User Boundary	Browser -> Auth0 IdP / Web Gateway	OAuth 2.0 PKCE, Mandatory MFA, Short-lived tokens
TB-2: Agent Boundary	Gateway -> AI Orchestrator Agent	JWT Claims (agent_id, trust_tier), Dual Guardrails
TB-3: RAG Retrieval	AI Agent -> Vector Database Store	Chunk Integrity Attestation, Metadata Provenance
TB-4: Inter-Agent RPC	Orchestrator -> MCP Tool Worker	Ed25519 Asymmetric Digital Signatures, Zero Trust
TB-5: Backend API	MCP Worker -> Internal REST APIs	M2M Client Credentials (TTL <= 300s), Granular Scopes

5. SECTION 1 — AI IDENTITY LIFECYCLE MANAGEMENT

5.1 Non-Human Identity (NHI) Provisioning & Approval Matrix: Every AI agent must be registered as a distinct Client Application within Auth0. Generic shared accounts are strictly prohibited. Formal provisioning requires approval from AI Platform Lead, IAM Administrator, and AI Security Lead.

5.2 Mandatory 90-Day Access Review Cycle: All provisioned AI identities, OAuth scopes, and API key bindings must undergo documented access certification every 90 calendar days. Unused scopes (stale for >30 days) are automatically pruned within 5 business days.

5.3 Continuous Telemetry & Runtime Monitoring: Structured JSON telemetry logs must be emitted to SIEM within ≤ 2 s of execution. Real-time anomaly baselines flag call spikes (>20 requests/60s), unauthorized scope jumps, and expired token replays.

5.4 Cryptographic Key Rotation & Token Lifecycles: Asymmetric Ed25519 signing keys rotate every 30 days. Model API keys have a maximum lifetime of 90 days. M2M OAuth tokens have a maximum TTL of 300 seconds.

5.5 Automated Identity Suspension & Quarantine: Automated IAM orchestration immediately suspends agents breaching anomaly thresholds (3+ guardrail violations in 60s or failed signature check) within ≤ 60 seconds.

5.6 Permanent Decommissioning & Audit Retention: Full credential revocation in ≤ 1 hour upon sunset. Telemetry and audit trails are retained in immutable WORM storage for 365 calendar days.

6. SECTION 2 — CREDENTIAL GOVERNANCE & SECRETS MANAGEMENT

6.1 Prohibition of Long-Lived Credentials: Standing long-lived API keys or static passwords are strictly prohibited in runtime environments, prompts, source code repositories, and config files.

6.2 Centralized Secrets Management: All provider API keys and M2M secrets must reside exclusively in enterprise Key Vaults (AWS Secrets Manager / HashiCorp Vault) encrypted with KMS customer-managed keys (AES-256-GCM).

6.3 Mandatory Maximum 90-Day API Key Rotation Protocol: All LLM API keys must rotate at least once every 90 calendar days using an automated zero-downtime dual-key rotation engine.

6.4 Short-Lived M2M Tokens (TTL ≤ 300 s) & Refresh Rotation: Maximum token lifetime of 300 seconds. Refresh Token Rotation enabled with 0s reuse grace interval.

6.5 Least Privilege & Scope Enforcement: Granular token scopes (read:ai-data vs billing:write). Dynamic claim injection via Auth0 post-login Actions.

6.6 Emergency Revocation & Break-Glass Workflow: Emergency secret revocation executes within ≤ 15 minutes of alert triage, propagating across edge gateways in ≤ 500 ms.

7. SECTION 3 — INCIDENT RESPONSE PLAYBOOK

7.1 Scenario A: Leaked LLM API Key

1. Detection Signals	- Secret scanning alert from GitHub Advanced Security / GitGuardian indicating public repository commit. - SIEM alert indicating anomalous API call volume (>10x baseline) or calls originating from unexpected geographic IP ranges. - Output guardrail regex scanner detecting API key pattern (sk-ant-api03-... or sk-proj-...) in model egress response. - LLM provider automated billing / quota spike warning.
2. Initial Triage (0 - 15 Mins)	- On-Call Security Engineer verifies the alert authenticity and identifies the exposed Key ID / Provider. - Determine exposure blast radius: check whether the key is associated with Production, Staging, or Development environments. - Verify if unauthorized LLM completions or data extraction occurred in provider request logs. - Assign Incident Severity Level: P1 (Critical) for Production keys, P2 (High) for Staging.
3. Containment (15 - 30 Mins)	- Immediately revoke the compromised API key via the provider management API / console. - Provision a temporary replacement key in Secrets Manager and deploy to active agent orchestrators. - Temporarily throttle public customer chat endpoints to prevent concurrent exploitation. - Block offending external IP addresses at Cloudflare / Edge WAF.
4. Evidence Preservation	- Snapshot and export provider API audit logs covering the 72-hour window prior to revocation. - Capture git commit hash, author metadata, and repository history containing the leaked secret. - Export SIEM telemetry records, container runtime logs, and output guardrail alert payloads. - Generate SHA-256 cryptographic hashes of all exported log files for forensic chain-of-custody.
5. Notification & Escalation	- Escalate to Incident Commander, AI Platform Engineering Lead, and CISO within 15 minutes of P1 confirmation. - If customer PII was potentially accessible through prompt history, notify Legal & Data Privacy Officer within 2 hours. - Dispatch internal security advisory to engineering teams regarding secret hygiene.
6. Eradication	- Perform full git history purge using git-filter-repo / BFG Repo-Cleaner to permanently scrub secret from all branches. - Audit all environment variable definitions across Kubernetes clusters and CI/CD pipelines. - Verify that no secondary backdoors or automated extraction cron jobs were established in agent memory.
7. Recovery	- Verify normal operational status of AI agent customer service platform using new rotated keys. - Run automated synthetic health checks (pytest tests/test_agent_health.py) to confirm 200 OK responses. - Monitor LLM provider billing metrics and SIEM telemetry for 48 hours to ensure zero residual unauthorized calls.
8. Post-Incident Review	- Conduct formal Blameless Post-Mortem within 3 business days with AI Platform and Security teams. - Document root cause (e.g., developer bypass of pre-commit hook, misconfigured debug logging). - Publish Post-Incident Report (PIR) with corrective action items (e.g., enforce mandatory pre-commit hooks).
9. Required Logs / Evidence	- LLM Provider request logs (timestamp, IP, prompt tokens, model response hashes). - GitHub commit / PR audit logs and secret scanner detection alerts. - SIEM structured telemetry records (audit_logs.json). - HashiCorp Vault / AWS Secrets Manager secret modification audit logs.

10. Responsible Roles

- Incident Commander: AI Identity Security Lead.
- Technical Lead: AI Platform Engineering Lead.
- Operations / Containment: IAM / Auth0 Administrator & On-Call SOC Engineer.
- Communications & Compliance: CISO & Legal Counsel.

7.2 Scenario B: Compromised AI Agent Identity / Spoofed Agent

1. Detection Signals	- Anomaly detection alert: UNAUTHORIZED_SCOPE_CHANGE_DETECTED or SIGNATURE_VERIFICATION_FAILED on inter-agent RPC. - High-privilege tool execution attempt (issue_billing_refund or delete_user_account) by an unapproved caller ID. - Auth0 Attack Protection alert: Suspicious IP throttling or multiple failed M2M token requests for client_cs_agent_... - Agent B rejecting tampered messages with asymmetric digital signature mismatch errors.
2. Initial Triage (0 - 15 Mins)	- SOC analyst correlates agent invocation logs with Auth0 token issuance telemetry. - Identify the affected agent ID and verify whether unauthorized tool actions succeeded or were blocked. - Check if Ed25519 private keys were exposed or if unauthenticated JSON payloads bypassed validation. - Classify severity: P1 (Critical) if financial/administrative tools executed; P2 (High) if blocked at gateway.
3. Containment (15 - 30 Mins)	- Immediately disable the compromised agent's Auth0 Client Application via Auth0 Management API (client_id suspended). - Trigger instant revocation of all active M2M tokens and refresh tokens associated with the agent. - Sever network connectivity between the compromised agent container and MCP tool execution gateways. - Rotate the master Ed25519 signing key pair in KMS and flush all public key caches.
4. Evidence Preservation	- Snapshot memory and container state of the compromised agent pod for forensic inspection. - Export all Auth0 audit logs, including client credentials grants, token exchange, and post-login action logs. - Capture raw inter-agent RPC payloads, HTTP headers, digital signatures, and MCP server logs. - Archive structured JSON audit trail with cryptographic timestamps.
5. Notification & Escalation	- Notify CISO, Head of Engineering, and AI Platform Owner within 15 minutes of P1 confirmation. - Alert the Customer Support operations lead if agent suspension impacts live customer ticketing. - Activate technical incident war-room on enterprise communications channel.
6. Eradication	- Terminate and redeploy all agent pods from trusted, immutable container base images. - Enforce strict Ed25519 signature verification on all MCP tool worker endpoints (Zero Trust). - Verify that Auth0 post-login Actions strictly enforce agent_id claim binding and reject untrusted tokens. - Validate that no lingering malicious credentials remain in agent memory.
7. Recovery	- Re-provision new Auth0 M2M credentials and deploy new Ed25519 key pair to production. - Execute automated regression test suite (python scripts/run_blue_team.py) to verify signature validation. - Restore agent traffic gradually (10% -> 50% -> 100%) while monitoring SIEM anomaly alert streams. - Confirm 100% rejection rate for unsigned or spoofed RPC envelopes.
8. Post-Incident Review	- Conduct Root Cause Analysis (RCA) within 3 business days. - Evaluate why spoofed/compromised material was accepted (e.g., missing signature check in legacy endpoint). - Implement architectural hardening to eliminate implicit trust across all microservices.
9. Required Logs / Evidence	- Auth0 Management & Authentication logs (Client Credentials grants, IP addresses, user agents). - MCP Gateway RPC logs (sender_id, digital_signature, tool_name, execution result). - Anomaly detection alert telemetry (anomaly_alerts.json). - Ed25519 key rotation logs and verification event traces.

10. Responsible Roles

- Incident Commander: AI Identity Security Lead.
- IAM Response Lead: Auth0 / IAM Administrator.
- Platform Forensics: AI Platform Engineering Lead.
- Executive Oversight: CISO.

7.3 Scenario C: Successful Prompt Injection Data Exfiltration

1. Detection Signals	- Pre-LLM / Post-LLM Guardrail alert: SYSTEM_OVERRIDE_FLAGGED, INSTRUCTION_BYPASS_ATTEMPT, or JWT_SECRET_EXFILTRATED. - Output guardrail regex filter intercepting JWT bearer token (eyJhbGciOi...) or sensitive PII in model output. - Anomaly alert for unusual outbound RAG chunk retrieval volume or sensitive file downloads. - User report / CSR flagging unexpected assistant behavior revealing internal system instructions.
2. Initial Triage (0 - 15 Mins)	- Review the exact conversation session ID, user prompt payload, and raw model response buffer. - Determine injection type: Direct prompt injection (chat input) or Indirect prompt injection (malicious invoice/RAG document). - Assess whether sensitive data (JWT token, customer PII, system prompt) was delivered to the adversary. - Assign Severity: P1 (Critical) if active session tokens or bulk customer PII exfiltrated; P2 (High) if intercepted by output regex.
3. Containment (15 - 30 Mins)	- Immediately terminate the affected user session and revoke the active Auth0 Session JWT. - If indirect injection via poisoned RAG chunk: instantly isolate and quarantine the affected vector database index. - Tighten input guardrail heuristic rules to block the adversary's specific bypass syntax. - Enable aggressive output redaction mode ([REDACTED_IDENTITY_JWT_TOKEN]) across all model egress streams.
4. Evidence Preservation	- Export the complete conversation transcript including system prompt, user prompt, retrieved RAG context, and model output. - Capture raw adversarial document/payload (e.g., Invoice_#8821.pdf) and document hash. - Extract vector database ingestion metadata to identify who uploaded the poisoned chunk and when. - Archive all guardrail logs with execution timing and classification confidence scores.
5. Notification & Escalation	- Escalate to AI Identity Security Lead and CISO within 15 minutes of P1 confirmation. - If exfiltrated data includes customer personal data, notify Data Protection Officer (DPO) within 1 hour for regulatory reporting (GDPR/CCPA). - Brief customer support management on potential phishing or unauthorized account activity.
6. Eradication	- Purge the poisoned chunk from vector database storage and re-index affected knowledge base partitions. - Update guardrail engine (guardrails_engine.py) with new regex patterns, semantic classifiers, and boundary markers. - Refactor system prompts to enforce strict context compartmentalization and instruction delimiter isolation. - Implement cryptographic hashing and approval gates on all future RAG document ingestion.
7. Recovery	- Re-run full Red Team prompt injection suite (python scripts/run_red_team.py) against hardened guardrails. - Verify that all 5 prompt injection attack vectors (SEC-ADV-01 to SEC-ADV-05) return 100% BLOCKED status. - Re-enable normal RAG retrieval services and resume standard customer chat routing. - Maintain enhanced real-time egress monitoring for 72 hours.
8. Post-Incident Review	- Conduct comprehensive Post-Mortem within 5 business days. - Map exploit mechanics to MITRE ATLAS techniques (AML.T0051, AML.T0043, AML.T0016). - Update SecureNova Threat Model and Risk Priority Matrix with new adversary techniques.
9. Required Logs / Evidence	- Raw user session conversation logs with full context window traces. - Vector database retrieval query logs and similarity score traces. - Guardrail decision audit records showing pre-LLM and post-LLM filter results. - Auth0 token revocation and session invalidation logs.

10. Responsible Roles

- Incident Commander: AI Identity Security Lead.
- Guardrail / Model Engineering: AI Platform Engineering Lead.
- Data Privacy & Compliance: Data Protection Officer (DPO) & Legal.
- Operations & Monitoring: SOC Team.